

RELATÓRIO DE GESTÃO DE IDENTIDADES E ACESSOS (IAM)



Formando: Odair Santos Mota

Formador: Valério Santos

Modulo: Linux e Segurança na Cloud

Índice

Proposta de Controlo de Acessos para Mini-Servidor Linux – Tópico 02	1
1. Identificação do Grupo e Autoria	1
2. Síntese do Cenário	1
3. Perfis, Grupos e Responsabilidades.....	1
4. Estrutura de Diretórios Proposta.....	3
5. Proposta de Permissões Octais e Donos.....	3
6. Regras de Acesso Remoto por SSH	5
Boas Práticas e Cuidados Críticos com SSH:	6
7. Riscos e Medidas de Mitigação	7
8. Conclusão Final.....	8

Proposta de Controlo de Acessos para Mini-Servidor Linux – Tópico 02

1. Identificação do Grupo e Autoria

- **Identificação do Grupo:** Trabalho Adaptado para Regime Individual
- **Autor / Formando:** Odair Santos Mota
- **Perfil Profissional / Papéis Assumidos:** Administrador de Sistemas Linux, Especialista em IAM (Identity and Access Management) e Auditor de Segurança Informática.

2. Síntese do Cenário

O cenário em análise apresenta um mini-servidor Linux configurado para alojar uma aplicação web corporativa, o qual será partilhado por quatro perfis distintos de utilizadores: Administradores, Operadores Web, Auditores e Visitantes Técnicos.

A auditoria inicial identificou falhas graves de segurança (*gaps*) na infraestrutura: a partilha de credenciais únicas entre colaboradores, a atribuição excessiva de privilégios (abuso do utilizador root), a ausência de restrições de escrita em diretórios críticos de configuração, o acesso remoto via SSH desregulado e a total falta de rastreabilidade (auditoria) sobre as ações executadas. A estratégia proposta abaixo visa neutralizar estes riscos através da aplicação estrita do Princípio do Menor Privilégio e da segregação lógica de funções.

3. Perfis, Grupos e Responsabilidades

Para erradicar o uso de contas partilhadas, cada utilizador terá uma conta individual associada a grupos específicos do sistema operativo, mapeados na seguinte matriz de responsabilidades:

Perfil	Grupo Sugerido	Responsabilidades Primárias	Permissões Necessárias	Permissões a Evitar
Administrador	admins	Gestão de utilizadores,	Acesso completo via	Uso direto do utilizador root

Perfil	Grupo Sugerido	Responsabilidades Primárias	Permissões Necessárias	Permissões a Evitar
		configuração de serviços, auditoria global e atualizações do SO.	sudo mapeado em /etc/sudoers.	para tarefas quotidianas.
Operador Web	webops	Publicação, manutenção e atualização dos ficheiros de código da aplicação web.	Escrita e leitura restrita à diretoria de produção /opt/projeto-web/public.	Acesso a ficheiros de sistema ou bases de dados.
Auditor	auditores	Consulta de logs de segurança, verificação de conformidade e leitura de relatórios.	Leitura estrita de logs (/var/log) e pastas de documentação do sistema.	Qualquer permissão de escrita ou alteração de configurações.
Visitante Técnico	visitantes	Consulta pontual de documentação autorizada e dados técnicos públicos.	Leitura estrita da diretoria de documentação /opt/projeto-web/docs.	Acesso a dados sensíveis, logs ou ficheiros de código fonte.

4. Estrutura de Diretórios Proposta

A árvore de diretórios foi centralizada em `/opt/projeto-web/` para garantir um isolamento limpo da aplicação face ao resto do sistema operativo:

`/opt/projeto-web/`

- |— `public/` --> Ficheiros públicos da aplicação (HTML, CSS, JS, Imagens)
- |— `config/` --> Ficheiros sensíveis de configuração (Credenciais, chaves de API)
- |— `logs/` --> Registos de eventos e erros gerados pela aplicação web
- |— `docs/` --> Documentação técnica e manuais de operação autorizados

- **public/**: Leitura por todos os utilizadores e servidores web (Apache/Nginx). Escrita exclusiva para o grupo webops e admins. **Risco de privilégio excessivo**: Modificação maliciosa do site (*Defacement*) ou injeção de malware se utilizadores comuns puderem escrever aqui.
- **config/**: Leitura e escrita exclusivas do administrador (admins) e leitura restrita ao utilizador que corre o serviço web (ex: `www-data`). **Risco de privilégio excessivo**: Fuga de credenciais de bases de dados e chaves criptográficas.
- **logs/**: Escrita apenas pelo serviço web. Leitura autorizada para admins e auditores. **Risco de privilégio excessivo**: Eliminação de logs por parte de atacantes para ocultar vestígios de intrusão.
- **docs/**: Leitura livre para todos os perfis técnicos do servidor. Escrita exclusiva de admins. **Risco de privilégio excessivo**: Fuga de metodologias proprietárias se alterado sem controlo.

5. Proposta de Permissões Octais e Donos

Para traduzir a política de privilégio mínimo em controlos de sistema nativos do Linux, aplicamos a atribuição rigorosa de utilizadores e grupos (*owners/groups*) combinada com permissões numéricas (octais):

Caminho	Dono Sugerido	Grupo Sugerido	Permissão Octal	Justificação Técnica
<code>/opt/projeto-web/</code>	root	root	755	A raiz do projeto deve ser protegida

Caminho	Dono Sugerido	Grupo Sugerido	Permissão Octal	Justificação Técnica
				contra alterações estruturais por utilizadores comuns.
.../public/	root	webops	775	Permite ao grupo de operadores web atualizar o código, mantendo a leitura pública para o servidor web.
.../config/	root	admins	740	Isolamento crítico. Apenas o administrador lê/escreve, e utilizadores comuns não têm qualquer acesso visível.
.../logs/	www-data	auditores	750	O serviço web (www-data) escreve os logs, o grupo de auditores lê, e os restantes utilizadores são bloqueados.
.../docs/	root	visitantes	755	Permite que visitantes e técnicos leiam manuais sem risco de alteração ou

Caminho	Dono Sugerido	Grupo Sugerido	Permissão Octal	Justificação Técnica
				eliminação dos dados originais.

6. Regras de Acesso Remoto por SSH

A política de acessibilidade remota dita que **apenas contas individuais autorizadas** podem estabelecer sessões virtuais, abolindo o uso do utilizador genérico osboxes e o login direto de contas administrativas seniores.

Perfil	Pode aceder por SSH?	Tipo de Autenticação	Justificação Operacional
Administrador	SIM	Chave Pública/Privada (Ed25519)	Necessário para manutenção, blindado com chaves criptográficas de alta entropia.
Operador Web	SIM	Chave Pública/Privada (Ed25519)	Necessário para deploy de código. Restrito ao seu ambiente através de rshell/permissões.
Auditor	SIM	Palavra-passe Forte + MFA	Acesso esporádico. Monitorizado e obrigado a rotação periódica de credenciais.

Perfil	Pode aceder por SSH?	Tipo de Autenticação	Justificação Operacional
Visitante Técnico	NÃO	BLOQUEADO	Não possui justificativa operacional que sustente acesso à consola bash do servidor.

Boas Práticas e Cuidados Críticos com SSH:

1. **Desativar Login Direto do Root:** No ficheiro `/etc/ssh/sshd_config`, definir obrigatoriamente `PermitRootLogin no`.
2. **Uso de Chaves Criptográficas:** Substituir a autenticação tradicional por chaves SSH, desativando palavras-passe fracas (`PasswordAuthentication no` para administradores).
3. **O que NUNCA publicar:** Chaves privadas SSH (`id_rsa` / `id_ed25519`), ficheiros de passwords em texto limpo ou o conteúdo do ficheiro `/etc/shadow`.
4. **Risco de Acesso Administrativo Generalizado:** Se todos os utilizadores possuírem privilégios de `sudo`, o sistema perde a rastreabilidade (não se sabe quem executou comandos destrutivos) e um erro accidental de um operador web pode derrubar todo o servidor de produção.

7. Riscos e Medidas de Mitigação

Mapeamento dos vetores de ameaça identificados no mini-servidor e as ações mitigadoras correspondentes:

Risco Identificado	Impacto Estimado	Medida de Mitigação Proposta (Hardening IAM)
Partilha de Contas Genéricas (ex: uso partilhado de osboxes)	ALTO: Perda completa de auditoria; impossibilidade de imputar responsabilidade por alterações.	Eliminar contas genéricas e criar utilizadores nominais individuais para cada técnico do projeto.
Utilização Excessiva da Conta Root	CRÍTICO: Compromisso total do sistema operativo em caso de comandos errados ou invasões.	Configurar o ficheiro /etc/sudoers para permitir apenas comandos específicos via sudo para utilizadores rastreados.
Privilégios Excessivos em Pastas	ALTO: Modificação indesejada de ficheiros de sistema e destruição de código fonte.	Aplicação estrita de permissões octais de menor privilégio (750 e 740) em diretórios sensíveis.
Acesso SSH Sem Regras Técnicas	CRÍTICO: Ataques de força bruta bem-sucedidos e conexões de localizações geográficas hostis.	Alterar a porta padrão do SSH (ex: de 22 para 2222), banir login de root e instalar o utilitário Fail2Ban.

Risco Identificado	Impacto Estimado	Medida de Mitigação Proposta (Hardening IAM)
Ficheiros de Configuração Expostos	ALTO: Fuga de senhas de bases de dados, permitindo pivots de ataque internos.	Alterar o dono para root:admins com permissão 640 ou 400 nos ficheiros que contêm segredos (wp-config.php, .env).

8. Conclusão Final

A transição do mini-servidor Linux de um estado de vulnerabilidade acentuada para um ambiente em conformidade com as melhores práticas de mercado prova que o controlo de identidades e acessos (IAM) é a primeira linha de defesa de qualquer infraestrutura.

A eliminação de contas partilhadas, o isolamento físico e octal da árvore /opt/projeto-web/ e a blindagem do serviço SSH convertem o servidor num sistema resiliente. Estas decisões asseguram a integridade do código da aplicação, garantem o sigilo das configurações de backend e, acima de tudo, fornecem logs de auditoria fiáveis e detalhados para futuras análises de conformidade.